

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

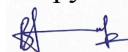
«Технология обнаружения уязвимостей в автоматизированных системах»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №2

«BlueKeep (RDP) — CVE-2019-0708»

Выполнили:

Чан Бао Линь, студентка группы N3446



(подпись)

(подпись)

Проверил:

к.т.н., доц., Менщиков Александр Алексеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025 г.

СОДЕРЖАНИЕ

Содержание.....	2
Введение.....	3
1 Ход работы.....	4
1.1 CVE.....	4
1.2 CVSSv4 (подробно).....	4
1.3 CWE.....	5
1.4 Подходящие техники MITRE ATT&CK.....	6
1.5 Статус наличия эксплойта.....	6
1.6 Перечень диапазонов уязвимых версий.....	7
Заключение.....	8
Список использованных источников.....	9

ВВЕДЕНИЕ

Цель работы

Целью данной работы является проведение комплексного анализа известной уязвимости удаленного выполнения кода "BlueKeep" (CVE-2019-0708), демонстрация ее критической опасности и систематизация данных, необходимых для ее идентификации, оценки рисков и устранения.

Для достижения поставленной цели необходимо решить следующие задачи:

1. Идентифицировать уязвимость в общепризнанных базах данных (CVE) и классифицировать ее тип согласно иерархии Common Weakness Enumeration (CWE).
2. Провести оценку уровня опасности уязвимости с использованием современной методологии Common Vulnerability Scoring System v4.0 (CVSSv4), подробно разобрав ее базовые метрики и метрики влияния.
3. Определить тактики и техники из матрицы MITRE ATT&CK, в рамках которых данная уязвимость может быть использована злоумышленниками для проникновения и распространения в инфраструктуре.
4. Проанализировать статус наличия и доступности эксплойтов для данной уязвимости.
5. Составить точный перечень уязвимых версий программного обеспечения, а также указать меры по устранению угрозы.

1 Ход работы

1.1 CVE

CVE-2019-0708 (BlueKeep) - Существует уязвимость удалённого выполнения кода в службах удалённого рабочего стола (Remote Desktop Services), ранее известных как Terminal Services, когда неаутентифицированный злоумышленник подключается к целевой системе по протоколу RDP и отправляет специально сформированные запросы; также известна как «Remote Desktop Services Remote Code Execution Vulnerability».

1.2 CVSSv4 (подробно)

Итоговый балл: 10.0 (Critical)

Вектор: CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H



Common Vulnerability Scoring System Version 4.0 Calculator

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H

Reset

CVSS v4.0 Score: **10 / Critical** ⓘ

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AT):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	<input checked="" type="button" value="None (N)"/>	Low (L)	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	<input checked="" type="button" value="High (H)"/>	Low (L)
Integrity (VI):	<input checked="" type="button" value="High (H)"/>	Low (L)
Availability (VA):	<input checked="" type="button" value="High (H)"/>	Low (L)

Subsequent System Impact Metrics		
Confidentiality (SC):	<input checked="" type="button" value="High (H)"/>	Low (L)
Integrity (SI):	<input checked="" type="button" value="High (H)"/>	Low (L)
Availability (SA):	<input checked="" type="button" value="High (H)"/>	Low (L)

Рисунок 1 - Base Metrics

- Эта оценка отражает максимальный риск, поскольку уязвимость позволяет удаленно выполнить код без аутентификации и может самораспространяться (является "червеобразной").

Метрики Эксплуатации (Exploitability Metrics):

- AV:N (Attack Vector: Network): Уязвимость эксплуатируется удаленно по сети. Целью является служба Remote Desktop Services (RDP).
- AC:L (Attack Complexity: Low): Для эксплуатации не требуются сложные или нестандартные условия. Атакующему достаточно отправить специально созданный пакет.
- AT:N (Attack Requirements: None): Новая метрика в v4. Показывает, что для атаки не требуются никакие предварительные действия или специфическое состояние системы (кроме включенного RDP).
- PR:N (Privileges Required: None): Эксплуатация происходит до аутентификации. Атакующему не нужны учетные данные.
- UI:N (User Interaction: None): Для атаки не требуется никаких действий со стороны пользователя (например, переход по ссылке или открытие файла).

Метрики Влияния на Уязвимую Систему (Vulnerable System Impact):

- VC:H (Confidentiality: High): Атакующий получает полный контроль над системой (уровень SYSTEM) и доступ ко всем данным.
- VI:H (Integrity: High): Атакующий может изменять любые файлы и параметры системы.
- VA:H (Availability: High): Атакующий может полностью вывести систему из строя (отказ в обслуживании) или использовать ее ресурсы.

Метрики Влияния на Последующие Системы (Subsequent System Impact):

- SC:H / SI:H / SA:H (Confidentiality/Integrity/Availability: High): Это ключевая особенность BlueKeep. Компрометация одной машины (сервера RDP) позволяет ей сканировать и атаковать другие уязвимые машины в той же сети. Это придает уязвимости "червеобразный" характер (как у WannaCry), что приводит к массовому влиянию на всю инфраструктуру (последующие системы).

1.3 CWE

- CWE-416: Use After Free (Использование после освобождения)
- Уязвимость возникает в драйвере termdd.sys, который некорректно обрабатывает объекты в памяти после того, как они были освобождены. Это позволяет атакующему перезаписать указатели в памяти и в конечном итоге выполнить произвольный код на уровне ядра (kernel level).

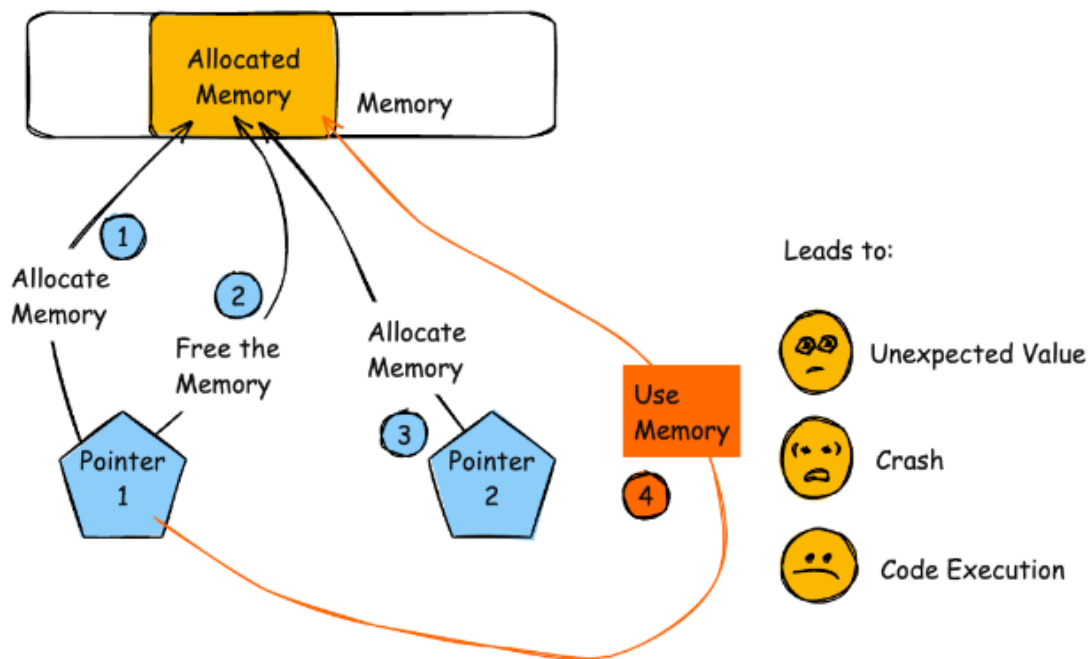


Рисунок 2 - Use After Free

1.4 Подходящие техники MITRE ATT&CK

Уязвимость BlueKeep используется на ранних стадиях атаки, в основном для проникновения и распространения.

- TA0001 - Initial Access (Первоначальный доступ)
 - T1190: Exploit Public-Facing Application (Эксплуатация общедоступного приложения)
 - Служба RDP часто выставлена в Интернет. BlueKeep используется для получения первоначального доступа к сети организации через такой незащищенный сервер.
- TA0008 - Lateral Movement (Латеральное перемещение)
 - T1210: Exploitation of Remote Services (Эксплуатация удаленных служб)
 - Это основной сценарий использования для "червя". После компрометации одного хоста, злоумышленник (или сам вредоносный код) использует BlueKeep для сканирования и атаки на другие серверы и рабочие станции внутри сети, у которых включен RDP.

1.5 Статус наличия эксплойта

- Эксплойт существует (публично доступен).

- Существуют как общедоступные модули для фреймворков (например, Metasploit), так и более продвинутые частные эксплойты. Уязвимость активно эксплуатировалась в реальных атаках, в том числе для развертывания майнеров криптовалют и программ-вымогателей.

1.6 Перечень диапазонов уязвимых версий

- Уязвимость затрагивает старые, но широко используемые на тот момент операционные системы Windows.
 - Windows 7 (все редакции, 32-bit и 64-bit, до SP1)
 - Windows Server 2008 R2 (все редакции, до SP1)
 - Windows Server 2008 (все редакции, 32-bit и 64-bit, до SP2)
- Также уязвимы системы, снятые с поддержки (End-of-Life), для которых Microsoft выпустила экстренные патчи:
 - Windows XP (SP3)
 - Windows Server 2003 (SP2)
- Не уязвимы: Windows 8, Windows 10, Windows Server 2012, 2016 и 2019.

ЗАКЛЮЧЕНИЕ

В ходе данной работы был проведен всесторонний анализ уязвимости BlueKeep, в результате которого были решены все задачи, поставленные во введении.

Была подтверждена ее официальная идентификация (CVE-2019-0708) и установлена точная причина — ошибка "Use After Free" (CWE-416) в драйвере служб удаленных рабочих столов.

Оценка по современной методологии CVSSv4 дала уязвимости максимальный балл 10.0 (Критический). Это обусловлено не только возможностью удаленного выполнения кода без аутентификации и участия пользователя (AV:N, PR:N, UI:N), но и ее "червеобразным" потенциалом. Высокие показатели влияния на последующие системы (SC:N, SI:N, SA:N) подтверждают, что уязвимость может использоваться для самораспространения по сети, что многократно увеличивает масштабы потенциального ущерба.

Анализ техник MITRE ATT&CK показал, что BlueKeep является эффективным инструментом на ключевых этапах атаки: как для первоначального доступа в инфраструктуру (T1190), так и для стремительного латерального перемещения внутри нее (T1210). Наличие публично доступных и активно используемых эксплойтов подтверждает, что данная угроза является не теоретической, а практической.

Уязвимость BlueKeep стала одним из самых значимых событий в области кибербезопасности 2019 года. Она послужила суровым напоминанием о рисках, связанных с эксплуатацией устаревших, но все еще широко распространенных операционных систем (таких как Windows 7 и Server 2008). Данный анализ демонстрирует критическую важность своевременного управления обновлениями (патч-менеджмента) и применения защитных мер, таких как отключение неиспользуемых служб и сетевая сегментация, для предотвращения катастрофических последствий подобных уязвимостей.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. <https://www.first.org/cvss/v4-0/cvss-v40-specification.pdf>
2. <https://nvd.nist.gov/vuln/detail/cve-2019-0708>
3. <https://cwe.mitre.org/data/definitions/416.html>